

CVEFixes experiments: Full Files as Input

Checkpoint 7

Lívia Cavalcanti

June 2026

Evaluation Metrics

Hit@1

Success rate at rank 1

$$\frac{1}{|Q|} \sum_q \mathbb{1}[\text{rank}_q = 1]$$

Fraction of queries where the correct match is ranked **first**.

Hit@5

Success rate in top 5

$$\frac{1}{|Q|} \sum_q \mathbb{1}[\text{rank}_q \leq 5]$$

Fraction of queries where the correct match appears in **top 5**.

MRR

Mean Reciprocal Rank

$$\frac{1}{|Q|} \sum_q \frac{1}{\text{rank}_q}$$

Average inverse rank across queries — rewards **higher** placements.

CWE Recall

Type coverage

$$\frac{|\text{CWE}_{\text{retrieved}}|}{|\text{CWE}_{\text{index}}|}$$

Fraction of distinct CWE types correctly retrieved **at least once**.

AutoPatch Dataset Results (n=225)

Embedder	H@1	H@5	MRR	CWE R.
<i>Structure-Only</i>				
Combined	0.8904	0.9589	0.9162	0.4978
GIN	0.7260	0.8767	0.7879	0.4427
WL	0.6986	0.7945	0.7363	0.4386
<i>CodeBERT pretrained</i>				
CodeBERT (baseline)	0.1533	0.2200	0.1826	0.2933
CodeBERT (seq)	0.7534	0.8630	0.7927	0.4121
CodeBERT (pat)	0.7123	0.8356	0.7677	0.4147

Source: `experiments/output/checkpoint5/20260505_141347_experiment_f59ab1/results.json`

RQ1: validated — structural *graph* representations are *effective* for vulnerability pattern retrieval in a synthetic dataset.

CVEfixes Dataset - Input: Function only

Question: Does the approach generalize to real-world vulnerabilities?

Real-World Dataset

CVEFixes [bhandari2021cvefixes] datasets is large dataset with real-world CVEs collected from the U.S. National Vulnerability Database, patches, and code changes.

Metric	Value
CVEs	11,873
Fix commits	12,107
File changes	51,342
Method changes	277,948
Repositories	4,249

Sampling criteria

Structurally distinguishable CWEs (e.g. UAF vs. OOB) to test pattern matching, not just code similarity
Balanced superclass(CWE) up to 20 entries and subclasses (CVE) to ensure retrieval feasibility

Parameter	Value
Total pairs	136
Index set	109
Query set	27
Unique CVEs (index)	60
Unique CVEs (query)	25
CWE classes	7

Results

Same-CWE Retrieval (n=109 index, 27 query)

Embedder	Hit@1	Hit@5	MRR	CWE Recall
GIN	0.259	0.778	0.315	0.202
Combined	0.111	0.778	0.223	0.189
CodeBERT (baseline)	0.080	0.1518	0.098	0.141
CodeBERT (seq)	0.556	0.926	0.555	0.264
CodeBERT (pat)	0.519	0.889	0.549	0.276

Source: cvefixes_experiments/output/pipeline_verification/results.json

Per-CWE Breakdown (CodeBERT Pattern, CWE Hit@k)

CWE	N	Hit@1	Hit@5	Hit@10
Integer Overflow (190)	4	75%	100%	100%
Input Validation (20)	4	75%	75%	100%
Resource Consump. (400)	3	67%	100%	100%
Use After Free (416)	4	50%	100%	100%
NULL Ptr Deref (476)	5	40%	80%	80%
Race Condition (362)	3	33%	100%	100%
OOB Write (787)	4	25%	75%	75%
Overall	27	51.9%	88.9%	92.6%

Source: same file (CodeBERT Pattern cell)

Highlights areas for improvement in embedding design or slicing strategy.

Results for File as Input

Retrieval by Graph Input Type (CVE) (n=132 index, 8 query)

Graph input	Embedder	Hit@1	Hit@5	MRR	CWE R.
<i>G_vuln: vulnerability-focused subgraph</i>					
G_vuln	Combined	0.500	0.750	0.603	0.194
G_vuln	CodeBERT (seq)	0.500	0.750	0.573	0.269
G_vuln	CodeBERT (pat)	0.500	1.000	0.656	0.331
<i>G_before: full pre-patch file</i>					
G_before	Combined	0.125	0.125	0.179	0.238
G_before	CodeBERT (seq)	0.625	1.000	0.792	0.350
G_before	CodeBERT (pat)	0.375	0.875	0.594	0.250

G_vuln sharpens the vulnerability signal, this increase the preprocessing but allows simple graph pattern to retrieve the vulnerability more correctly. *G_before* keeps the full pre-patch file context, which helps CodeBERT sequence models recover more hits, but the broader context weakens the graph signal.

Combined on G_vuln: Per-CWE Hit@k

CWE	N	Hit@1	Hit@5	Hit@10
CWE-476	1	0.000	0.000	1.000
CWE-362	2	0.500	0.500	0.500
CWE-400	4	0.750	1.000	1.000
CWE-190	1	0.000	1.000	1.000
Overall	8	0.500	0.750	0.875

From run

20260629_165056_cvefixes_retrieval_grid_f05322

Results for File as Input (Larger Dataset)

Retrieval by Graph Input Type (CVE) (n=439 index, 113 query)

Graph input	Embedder	Hit@1	Hit@5	MRR	CWE R.
<i>G_vuln: vulnerability-focused subgraph</i>					
G_vuln	Combined	0.292	0.434	0.0357	0.218
G_vuln	CodeBERT (seq)	0.602	0.752	0.0670	0.336
G_vuln	CodeBERT (pat)	0.496	0.673	0.575	0.322
<i>G_before: full pre-patch file</i>					
G_before	Combined	0.044	0.204	0.125	0.164
G_before	CodeBERT (seq)	0.549	0.735	0.618	0.314
G_before	CodeBERT (pat)	0.522	0.699	0.594	0.302

From runs:

Vulnerability: 20260629_100842_cvefixes_retrieval_grid_060f17

Before: 20260629_143613_cvefixes_retrieval_grid_4c44f8

Questions?

Livia Cavalcanti |  graph-rag/